Gerenciamento de roles e proteção de rotas

Fonte: Confluence. Revisado em 16/10/2026.

Depois do login, o cliente chama `GET /api/auth/me` com o token Supabase. A resposta informa a identidade, as roles ativas e as permissões efetivas. O endpoint exige usuário autenticado e ativo.

As permissões seguem o padrão `recurso.ação`, como `translators.read`, `quotes.write` e `quotes.approve`. O backend deve validar o token, o usuário ativo e a permissão necessária em cada endpoint. Esconder uma tela não protege a API.

Use `require_permission` com permissões distintas para leitura, escrita e ações especiais. Retorne 401 para token ausente, inválido ou expirado e 403 para usuário inativo, inexistente ou sem acesso.

Permissões novas devem ser cadastradas no seed `apps/server/app/modules/seed/seed_roles.py`. O gerenciamento de roles usa `GET /api/roles`, `GET /api/roles/permissions`, `POST /api/roles`, `PATCH /api/roles/{role_id}` e `PATCH /api/roles/{role_id}/status`.

O mobile deve carregar `/api/auth/me`, mapear rotas em `ROUTE_PERMISSIONS`, filtrar a sidebar e enviar o token Bearer nas chamadas. Para cada rota nova, teste sem token (401), sem permissão (403) e com acesso autorizado.